SAVEETHA
INSTITUTE OF MEDICAL AND TECHNICAL SCIENCES
(Declared as Deemed to be University under Section 3 of UGC Act 1956)

COMPUTER SCIENCE AND ENGINEERING

Nov – 2026

ASSIGNMENT – 2

Course Code : **CSA6303**

Course Name : **THREAT INTELLIGENCE AND NETWORK SECURITY**

Max Marks**: 50**

1	The finance office of a university receives an e-mail that appears to come from the vice-chancellor's office, asking the accounts officer to open an attached "budget revision" document and to approve an urgent payment. The attachment contains a macro that installs a trojan, and within hours the finance file server is encrypted. Apply your knowledge of malware and phishing to this case. Explain the types of malware (virus, worm, trojan, ransomware, spyware, rootkit and botnet agent) with their method of spreading, and identify which types are involved here. Explain the types of phishing (bulk, spear phishing, whaling, smishing, vishing and clone phishing) and classify this attack with reasons. Prepare a table of the warning signs in the e-mail (sender address, header mismatch, urgency, link and attachment) and describe the technical controls (SPF, DKIM, DMARC, attachment sandboxing, macro blocking) and the awareness measures that would have stopped the attack.	(10)	(CO2)	(BL3)
2	An online ticket-booking website sells tickets for a popular cricket match. Within seconds of the sale opening, its web servers become unreachable. The monitoring graph shows a very large rise in incoming traffic, thousands of half-open TCP connections, and many repeated requests for the search page from addresses all over the world. Analyse the incident by explaining how DoS and DDoS attacks differ, and the working of volumetric attacks (UDP flood and DNS or NTP amplification), protocol attacks (SYN flood) and application-layer attacks (HTTP flood), with the structure of the botnet that launches them. Explain how the security team can distinguish a DDoS attack from a genuine rush of customers. Recommend a response and prevention plan using rate limiting, SYN cookies, content delivery networks, traffic scrubbing, anycast and black-holing, and discuss the cost and side effects of each measure.	(10)	(CO2)	(BL4)
3	Sales staff of a company often work from a café that offers free public Wi-Fi. A security audit finds that an attacker sitting in the café could create a fake access point with the same name as the café network, redirect users to a copy of the company's web mail login page, and capture the data that passes over the network. Analyse the attacks that make this possible by explaining the working of man-inthe-middle attacks, the evil-twin access point, ARP spoofing, DNS spoofing, IP and	(10)	(CO2)	(BL4)

	e-mail spoofing, SSL stripping and packet sniffing, with a labelled sequence or network diagram of one attack. Differentiate passive from active attacks in this case. Describe how each attack is detected (for example, duplicate MAC addresses in the ARP table, certificate warnings and IDS alerts) and prevented (VPN, HTTPS with HSTS, WPA3, dynamic ARP inspection, port security and 802.1X), and discuss which measures the company can apply to staff laptops it does not control.			
4	A small private clinic has a reception computer, two doctors' laptops, a patientrecords server, a network printer, a Wi-Fi router and a few IP cameras on one flat network. The clinic has never tested its network for weaknesses. Apply the vulnerability assessment process to this network. Explain the steps of asset discovery, scanning (for example, with Nmap, Nessus or OpenVAS), identification of vulnerabilities, scoring with CVSS, prioritisation, reporting, remediation and rescanning; the difference between authenticated and unauthenticated scans and between network-based and host-based scans; and the difference between a vulnerability assessment and a penetration test. Prepare a sample findings table with at least five realistic vulnerabilities of this clinic (for example, default router password, outdated operating system, unpatched server software, open remote desktop port and unencrypted camera streams), giving for each the affected asset, CVSS severity rating, possible attack and recommended remediation.	(10)	(CO2)	(BL3)
5	The Security Operations Centre of a bank receives threat data from three kinds of sources: its own firewall, proxy and e-mail logs; free OSINT sources such as community threat-sharing platforms, malware-analysis sites, vulnerability databases and internet-scanning services; and a paid commercial feed. A new batch contains these entries: an IP address that was reported as malicious fourteen months ago, a domain that imitates the bank's login page and was reported yesterday, and a file hash that also matches a legitimate Windows utility. Evaluate the threat data sources and the quality of these entries. Compare internal, OSINT, community and commercial sources, explain the types of Indicators of Compromise (hashes, IP addresses, domains, URLs, e-mail artefacts, registry keys and file names) with the Pyramid of Pain, and judge each entry on timeliness, accuracy, relevance, context and the risk of false positives. Explain how feed formats such as STIX and TAXII help sharing, and recommend how the bank should select, integrate and retire indicators in its SIEM, including aging of indicators and removal of duplicates.	(10)	(CO2)	(BL5)

ANSWERS

1. Malware and Phishing Attacks

Introduction

Malware is malicious software designed to damage computers, steal information or gain unauthorized access.

Phishing is a cyberattack in which attackers send fake messages to trick users into sharing sensitive information or downloading malicious files.

Types of Malware

Malware	**Explanation**	**Method of spreading**
Virus	Attaches itself to files and infects other files.	Infected files and programs.
Worm	Copies itself and spreads automatically.	Network connections.
Trojan	Pretends to be legitimate software but performs malicious activities.	Fake applications and attachments.
Ransomware	Encrypts files and demands money to restore them.	Malicious attachments and links.
Spyware	Secretly collects user information.	Malicious downloads.
Rootkit	Hides malicious activities and provides unauthorized access.	Infected software and exploits.
Botnet Agent	Turns a computer into a remotely controlled device.	Malware downloads and infected files.

Malware Involved in This Case

1. Trojan: The fake budget revision attachment installs a trojan.
2. Ransomware: The ransomware encrypts the university finance file server.

Types of Phishing

Type	**Explanation**
Bulk phishing	Sends fake emails to many people.
Spear phishing	Targets a specific person or organization.

Whaling	Targets senior officials and executives.
Smishing	Phishing through SMS messages.
Vishing	Phishing through phone calls.
Clone phishing	Replaces a genuine message or attachment with a malicious copy.

Classification of the Given Attack

The attack is a combination of spear phishing and whaling.

- Spear phishing because the email targets a specific accounts officer.
- Whaling because the attacker pretends to be the vice-chancellor's office, impersonating a senior official to influence the victim.

Warning Signs in the Email

Warning sign	**Explanation**
Sender address	The email address may be fake or different from the official address.
Header mismatch	Sender details may not match the actual sending server.
Urgency	The email demands immediate payment approval.
Link	Suspicious links may redirect users to fake websites.
Attachment	Unexpected budget documents may contain malicious macros.

Technical Controls

1. SPF: Checks whether the sending server is authorized to send emails for a domain.
2. DKIM: Uses digital signatures to verify email integrity and domain authentication.
3. DMARC: Helps prevent email domain spoofing by applying authentication policies.
4. Attachment Sandboxing: Opens suspicious attachments in a safe environment to detect malware.

5. Macro Blocking: Prevents untrusted documents from running dangerous macros.

Awareness Measures

- Train employees to identify fake emails.
- Avoid opening unknown attachments.
- Verify urgent payment requests through official channels.
- Check sender addresses carefully.
- Report suspicious emails to the IT department.

Conclusion: The university can prevent phishing and malware attacks by using email security controls, attachment scanning and employee awareness training.

2. DoS and DDoS Attacks

Introduction

Denial of Service (DoS) and Distributed Denial of Service (DDoS) are cyberattacks that make websites and network services unavailable by sending excessive traffic.

Difference Between DoS and DDoS

DoS	**DDoS**
Attack comes from a single source.	Attack comes from multiple sources.
Easier to identify.	Difficult to identify.
Usually has limited attack traffic.	Can generate very large traffic.
Easier to block.	More difficult to stop.

Types of DDoS Attacks

1. Volumetric Attacks

These attacks consume network bandwidth by sending large amounts of traffic.

- UDP Flood: Sends a large number of UDP packets to overwhelm the target.
- DNS Amplification: Uses DNS servers to send large responses to the victim.
- NTP Amplification: Uses NTP servers to generate amplified traffic towards the victim.

2. Protocol Attacks

- SYN Flood: Sends many TCP SYN requests without completing the TCP connection.
- This creates thousands of half-open connections and consumes server resources.

3. Application-Layer Attacks

- HTTP Flood: Sends repeated HTTP requests to a website.
- It overloads web servers and makes the website unavailable.

A botnet contains:

1. Attacker: Controls the attack.
2. Command and Control (C2) Server: Sends instructions to infected devices.
3. Bots: Infected computers or devices that generate attack traffic.
4. Target Server: The website or network being attacked.

DDoS Attack vs Genuine Customer Traffic

Genuine customer traffic	**DDoS attack**
Users access different pages.	Repeated requests may target one page.
Traffic follows normal patterns.	Traffic increases suddenly.
Requests are usually distributed naturally.	Requests may come from suspicious IP addresses.
Users complete connections.	Many half-open connections may appear.

Normal user behaviour.	Automated and abnormal behaviour.

Response and Prevention Measures

Security measure	**Explanation**	**Cost or side effect**
Rate Limiting	Limits the number of requests from a source.	May affect genuine heavy users.
SYN Cookies	Protects servers from SYN flood attacks.	Provides limited protection against other attack types.
CDN	Distributes website traffic across multiple servers.	Requires subscription and configuration.
Traffic Scrubbing	Removes malicious traffic before reaching the server.	Can be expensive and introduce delay.
Anycast	Distributes traffic across multiple network locations.	Requires suitable network infrastructure.
Black-holing	Drops traffic directed towards a target IP address.	Can also block genuine customer traffic.

Response Plan

1. Identify abnormal traffic using network monitoring.
2. Activate DDoS protection services.
3. Apply rate limiting to suspicious traffic.
4. Enable SYN cookies to reduce half-open connections.
5. Use CDN and traffic scrubbing services.
6. Monitor traffic until the website returns to normal.

Conclusion: DDoS protection methods help websites maintain availability and provide uninterrupted services during large-scale attacks.

3. Man-in-the-Middle Attacks and Spoofing

Introduction

A Man-in-the-Middle (MITM) attack occurs when an attacker secretly intercepts communication between two parties.

In this case, an attacker creates a fake café Wi-Fi access point and redirects company employees to a fake webmail login page to steal their information.

Types of Attacks

1. Man-in-the-Middle Attack
   - The attacker secretly intercepts communication between a user and a server.
   - The attacker may read or modify transmitted information.
2. Evil Twin Access Point
   - The attacker creates a fake Wi-Fi network with the same name as a genuine network.
   - Users connect to the fake network.
   - The attacker can monitor their traffic.
3. ARP Spoofing
   - The attacker sends fake ARP messages.
   - The victim connects to the attacker's MAC address instead of the correct gateway MAC address.
4. DNS Spoofing
   - The attacker provides fake DNS information.
   - Users are redirected to malicious websites.
5. IP Spoofing
   - The attacker changes the source IP address in network packets.
   - It makes packets appear to come from another system.
6. Email Spoofing
   - The attacker creates an email with a forged sender address.
   - It makes the email appear to come from a trusted person.
7. SSL Stripping

- The attacker attempts to downgrade a secure HTTPS connection to an insecure HTTP connection.
- This can expose sensitive information.

8. Packet Sniffing

- The attacker captures network packets to collect information.
- Unencrypted data may be exposed.

Working of the Attack

1. The employee connects to free café Wi-Fi.
2. The attacker creates a fake access point with the same network name.
3. The employee connects to the attacker's access point.
4. The attacker redirects the employee to a fake company webmail login page.
5. The employee enters their username and password.
6. The attacker captures the login details and may intercept network communication.

Passive and Active Attacks

Passive attacks	**Active attacks**
Packet sniffing	ARP spoofing
Eavesdropping	DNS spoofing
Traffic monitoring	IP spoofing
Observing communication	Evil twin access point
	SSL stripping

Passive attacks collect information without changing communication. Active attacks modify, redirect or interfere with communication.

Detection Methods

Attack	**Detection method**
MITM	IDS alerts and unusual traffic
Evil Twin	Detect duplicate Wi-Fi network names

ARP Spoofing	Check duplicate MAC addresses in ARP table
DNS Spoofing	Monitor unusual DNS responses
IP Spoofing	Check invalid source addresses
Email Spoofing	Check email headers
SSL Stripping	Detect certificate and HTTPS warnings
Packet Sniffing	Monitor suspicious network activity

Prevention Methods

1. VPN: Encrypts network communication.
2. HTTPS with HSTS: Forces secure HTTPS connections.
3. WPA3: Provides stronger Wi-Fi security.
4. Dynamic ARP Inspection: Prevents invalid ARP messages.
5. Port Security: Restricts unauthorized devices on network ports.
6. 802.1X: Provides authentication before allowing network access.

Measures for Staff Laptops

- Install and regularly update antivirus software.
- Use a company-approved VPN.
- Enable firewall protection.
- Avoid connecting to unknown Wi-Fi networks.
- Use HTTPS websites.
- Enable automatic security updates.
- Use multi-factor authentication.

Conclusion: MITM and spoofing attacks can be prevented through encryption, secure Wi-Fi, VPNs and proper network monitoring.

4. Vulnerability Assessment Process

Introduction

Vulnerability assessment is the process of identifying, analysing and prioritising security weaknesses in a computer network.

In this case, a private clinic has computers, laptops, a patient records server, printer, Wi-Fi router and IP cameras. All these devices must be checked for security weaknesses.

1. Asset Discovery

- Identify all devices connected to the network.
- Prepare a list of computers, laptops, servers, printers, routers and cameras.

2. Scanning

- Scan the network to identify open ports and running services.
- Use tools such as Nmap, Nessus and OpenVAS.

3. Identification of Vulnerabilities

- Identify outdated software.
- Find weak passwords.
- Check open ports and insecure services.

4. Scoring with CVSS

CVSS stands for Common Vulnerability Scoring System.

It measures the severity of vulnerabilities on a scale from 0 to 10.

CVSS score	**Severity**
0.1–3.9	Low
4.0–6.9	Medium
7.0–8.9	High
9.0–10.0	Critical

5. Prioritisation

- Fix critical and high-risk vulnerabilities first.
- Give priority to vulnerabilities affecting patient records.

6. Reporting

- Prepare a report containing vulnerabilities, severity and recommendations.

7. Remediation

- Update software.

- Change default passwords.
- Close unnecessary ports.
- Encrypt sensitive data.

8. Re-scanning

- Scan the network again after fixing vulnerabilities.
- Verify whether the security problems have been resolved.

Authenticated and Unauthenticated Scanning

Authenticated scanning	**Unauthenticated scanning**
Uses valid login credentials.	Does not use login credentials.
Provides detailed internal information.	Shows weaknesses visible to outsiders.
Checks installed software and configurations.	Checks open ports and exposed services.

Network-Based and Host-Based Scanning

Network-based scanning	**Host-based scanning**
Checks network devices and services.	Checks individual computers and servers.
Identifies open ports.	Identifies outdated software.
Scans from the network.	Runs directly on the host.

Vulnerability Assessment vs Penetration Testing

Vulnerability Assessment	**Penetration Testing**
Identifies security weaknesses.	Tests whether weaknesses can be exploited.
Focuses on finding vulnerabilities.	Focuses on demonstrating real attack possibilities.
Usually uses automated scanning tools.	Uses manual testing and specialised tools.
Provides a list of vulnerabilities.	Provides evidence of successful exploitation within the test scope.

Sample Vulnerability Findings Table

The following are illustrative findings for the clinic, not actual scan results.

Affected asset	Vulnerability	CVSS severity (illustrative)	Possible attack	Remediation
Wi-Fi router	Default password	9.8 – Critical	Unauthorized router access	Change default password
Reception PC	Outdated OS	8.1 – High	Malware infection	Update operating system
Patient records server	Unpatched software	9.0 – Critical	Server compromise	Install security patches
Doctors' laptops	Open RDP port	7.5 – High	Remote unauthorized access	Restrict or disable RDP
IP cameras	Unencrypted video streams	6.5 – Medium	Video interception	Enable encrypted streams

Conclusion: Vulnerability assessment helps the clinic identify and fix network weaknesses, protecting patient information and improving network security.

5. Threat Data Sources and Indicators of Compromise (IOC)

Introduction

Threat data sources provide information about cyber threats, attackers and malicious activities.

A bank uses internal logs, free OSINT sources and paid commercial feeds to identify and prevent cyberattacks.

Types of Threat Intelligence Sources

1. Internal Sources

- Collect information from the organization's own systems.
- Examples: Firewall logs, proxy logs and email logs.

- Provide information about attacks happening inside the bank's network.

2. OSINT Sources

- Open-source intelligence provides publicly available threat information.
- Examples: Malware analysis websites, vulnerability databases and internet-scanning services.

3. Community Sources

- Information is shared by cybersecurity communities.
- Helps organizations learn about new threats.
- Example: Community threat-sharing platforms.

4. Commercial Sources

- Provide paid threat intelligence services.
- Offer detailed threat reports, malicious IP addresses and domain information.
- Help organizations identify new cyber threats.

Comparison of Threat Data Sources

Source	**Advantages**	**Limitations**
Internal	Organization-specific information	Limited to own network
OSINT	Free and easily available	Information may be outdated
Community	Shared threat information	Accuracy may vary
Commercial	Detailed and updated intelligence	Requires payment

Types of Indicators of Compromise (IOC)

IOC means evidence that indicates a computer or network may have been compromised.

IOC type	**Explanation**
Hashes	Unique digital values used to identify files.
IP Addresses	Identify suspicious network sources.

Domains	Identify malicious website names.
URLs	Identify suspicious web links.
Email Artefacts	Include suspicious sender addresses and email headers.
Registry Keys	Identify suspicious changes in Windows registry entries.
File Names	Identify known malicious files.

The Pyramid of Pain explains how difficult it is for attackers to change different indicators.

Level	**Indicator**	**Difficulty for attacker**
1	Hash Values	Trivial
2	IP Addresses	Easy
3	Domain Names	Simple
4	Network/Host Artifacts	Annoying
5	Tools	Challenging
6	TTPs	Tough

TTPs means Tactics, Techniques and Procedures.

Evaluation of Given Threat Entries

Entry 1: IP address reported as malicious fourteen months ago

- Timeliness: Low because the information is old.
- Accuracy: Needs verification.
- Relevance: May still be useful if the IP is active.
- Context: Check recent threat reports.
- False-positive risk: High if the IP has changed ownership or is shared.

Entry 2: Domain imitating the bank's login page reported yesterday

- Timeliness: High because it was reported recently.
- Accuracy: Should be verified.
- Relevance: High because it targets the bank's login page.

- Context: Investigate the domain and associated phishing activity.
- False-positive risk: Lower after verification.

Entry 3: File hash matching a legitimate Windows utility

- Timeliness: Depends on when it was collected.
- Accuracy: Needs careful verification.
- Relevance: Uncertain because it matches legitimate software.
- Context: Check file signature, source and behaviour.
- False-positive risk: High if used alone as a malicious indicator.

Five Characteristics of Good Threat Intelligence

1. Timeliness: Information should be updated regularly.
2. Accuracy: Information should be correct.
3. Relevance: Information should relate to the bank.
4. Context: Information should include background details.
5. False-positive control: Indicators should be verified before blocking.

STIX and TAXII

STIX (Structured Threat Information Expression)

- A standard language used to represent threat intelligence.
- Organizes information about threats, indicators and attackers.
- Makes threat information easier to understand and share.

TAXII (Trusted Automated Exchange of Intelligence Information)

- A protocol used to exchange threat intelligence.
- Helps organizations share threat information automatically.
- Supports communication between threat intelligence platforms.

Selecting and Managing Indicators in SIEM

1. Collect indicators from internal, OSINT, community and commercial sources.
2. Verify indicators before adding them to SIEM.

3. Remove duplicate indicators.
4. Check the age and accuracy of indicators.
5. Give priority to recent and relevant indicators.
6. Monitor indicators regularly.
7. Retire outdated or false indicators.
8. Update threat intelligence feeds regularly.

Conclusion: Threat intelligence sources and IOCs help banks detect malicious activities, identify cyber threats and protect financial information. STIX, TAXII and SIEM improve threat information sharing and security monitoring.